

Preliminary Progress Review (PPR) Report of 25-26J-058

25-26J-058

SecureTrustOTA: A Resilient and Trust-Based OTA Framework for IoT Devices

Student Details

Student Name	Student ID
Jayaweera N.S	IT22362780
Dilmith K.P.H.S	IT21832130
Mandira U.L.L.K	IT22365996
P A S N PERERA	IT22307262

Supervisor: Mr.Kavinga Yapa Abeywardana

Date of Submission: 11.01.2026

Table of Contents and Index

1. Introduction	4
1.1. Purpose	4
1.2 Definitions, Acronyms, and Abbreviations	5
1.3 Overview	6
2. Literature Review	7
2.1 Background and Current State	7
2.2 Secure OTA Frameworks	7
2.3 Zero Trust and Access Control	7
2.4 Lightweight Cryptography and Delta Updates	8
2.5 Anomaly Detection and Device Attestation	8
2.6 Fail Safe and Recovery Mechanisms	8
2.7 Industry Implementations	8
2.8 Summary of Literature Findings	9
2.2 Identification and significance of the problem	9
2.2.1 Research Problem Statement	9
2.2.2 Novelty and Uniqueness	10
2.2.3 Scientific and Technical Challenge	11
2.2.4 Significance and Impact	11
3. Research Questions	12
RQ1: Zero Trust Authorization Effectiveness	12
RQ2: Lightweight Secure Delivery Performance	12
RQ3: Anomaly Detection Accuracy and Overhead	12
RQ4: Fail Safe Recovery Reliability	12
RQ5: Integrated Framework Scalability	13
RQ6: Security Posture Improvement	13
RQ7: Practical Deployment Feasibility	13
4. Research Objectives	14
4.1 Main Objective	14

4.2 Specific Objectives.....	14
Component 1: Zero Trust Authorization Layer	14
Component 2: Lightweight Secure OTA Core.....	15
Component 3: Anomaly Detection Engine	16
Component 4: Fail Safe Update Engine	16
Integration and Validation (All Team Members)	18
5. Research Methodology.....	19
6. Anticipated Benefits	22
6.1 Benefits to Users.....	22
6.2 Contribution to Body of Knowledge.....	22
7. Scope and deliverables	23
7.1 Scope	23
7.2 Specified Deliverables	23
8. Research Constraints.....	24
9. Project plan and Schedule.....	25
10. Budget and Justification.....	26
11.1 Budget Justification	26
11. References.....	27
12. Appendices.....	30

1. Introduction

1.1. Purpose

This Project Proposal Report (PPR) serves as comprehensive documentation of the SecureTrustOTA research project, which aims to develop a resilient and trust based Over the Air (OTA) firmware update framework for Internet of Things (IoT) devices. The purpose of this document is to formally present the research problem, objectives, methodology, expected outcomes, and project timeline to the academic evaluation committee and project supervisors at the Sri Lanka Institute of Information Technology.

This PPR is intended for the following audience:

- **Project Supervisors and Co supervisors:** To provide detailed insight into the research direction, technical approach, and expected contributions.
- **Academic Evaluation Panel:** To assess the viability, novelty, and academic merit of the proposed research.
- **Research Team Members:** To establish unified understanding of responsibilities, objectives, and deliverables.
- **External Reviewers and Stakeholders:** To provide transparency regarding scope, methodology, and potential impact.

The document outlines the rationale for developing an integrated OTA security framework that combines zero trust authorization, lightweight secure delivery mechanisms, anomaly detection, and fail safe recovery systems.

1.2 Definitions, Acronyms, and Abbreviations

The following table provides definitions of key terms, acronyms, and abbreviations used throughout this document.

Term/Acronym	Definition/Expansion
OTA	Over the Air: Method of remotely distributing firmware updates without physical access
IoT	Internet of Things: Network of interconnected physical devices with sensors and connectivity
mTLS	Mutual Transport Layer Security: Bidirectional authentication protocol
ECC	Elliptic Curve Cryptography: Public-key cryptography with strong security and smaller keys
AES-CCM	Advanced Encryption Standard Counter with CBC-MAC: Combined encryption and authentication
RBAC	Role Based Access Control: Access control based on user roles
PBAC	Policy Based Access Control: Dynamic access control using contextual attributes
ESP32	Espressif Systems 32 bit Microcontroller: Popular IoT development board
ABAC	Attribute Based Access Control
Delta Update	Differential update transmitting only changes between firmware versions
Zero Trust	Security model: never trust, always verify with continuous validation
Firmware Attestation	Cryptographic verification of device firmware authenticity and integrity
Rollback Protection	Security mechanism preventing installation of older vulnerable firmware
A/B Partitioning	Dual slot firmware storage for safe updates with rollback capability
Anomaly Detection	Identifying abnormal patterns in device behavior or telemetry data

Table 1. List of Abbreviations

1.3 Overview

This Project Proposal Report is systematically organized to provide comprehensive information about the SecureTrustOTA research project. The document structure follows academic standards and is divided into major sections:

Section 1: Introduction - Establishes context, purpose, terminology, and document organization.

Section 2: Literature Review - Comprehensive survey of existing research in IoT security, OTA mechanisms, and trust frameworks.

Section 3: Problem Identification - Articulates the research problem, highlighting novelty and significance.

Section 4: Research Questions - Formulates key questions guiding the investigation.

Section 5: Research Objectives - Details main and specific objectives defining project scope.

Section 6: Research Methodology - Describes systematic approach, methods, and techniques.

Section 7: Data Sources and Analysis - Outlines data collection, testing environments, and analytical methods.

Section 8: Anticipated Benefits - Identifies expected contributions to users and academia.

Section 9: Scope and Deliverables - Defines boundaries and expected outcomes.

Section 10: Research Constraints - Identifies limitations and external factors.

Section 11: Project Schedule - Presents detailed timeline with milestones.

Section 12: Budget - Details financial resources and justifications.

2. Literature Review

2.1 Background and Current State

The rapid expansion of the Internet of Things has led to billions of connected devices being deployed across critical sectors including healthcare, transportation, manufacturing, smart cities, and industrial automation. These devices operate autonomously and require frequent firmware updates to patch vulnerabilities, enhance functionality, and maintain operational integrity. Over the Air update mechanisms have emerged as the standard solution for remotely delivering firmware modifications without requiring physical device access, significantly reducing maintenance costs and downtime. However, the current state of OTA systems presents significant security and reliability challenges that threaten the stability of IoT ecosystems worldwide.

Existing OTA frameworks primarily focus on secure transmission and update integrity through mechanisms like digital signatures, cryptographic hashes, and encrypted channels (TLS/HTTPS). While these approaches authenticate firmware packages, they fail to verify the operational state and trustworthiness of devices before updates are applied. Current solutions such as Eclipse Hawkbit, Mender, AWS IoT Device Management, and Azure IoT Update Service provide reliable distribution and rollback capabilities but lack integrated pre update anomaly detection that evaluates device health. This creates a critical gap where devices operating in compromised, infected, or resource exhausted states can still receive updates, potentially exacerbating vulnerabilities, propagating malware, or causing permanent device failures. Furthermore, traditional security mechanisms are often too resource intensive for constrained IoT devices with limited memory, processing power, and battery capacity. High profile incidents like the Mirai botnet attack have demonstrated the devastating consequences of exploiting unsecured IoT update processes, where compromised devices were weaponized for large scale DDoS attacks. The current state reveals an urgent need for lightweight, resilient OTA frameworks that integrate security, efficiency, and proactive trust verification throughout the entire update lifecycle.

2.2 Secure OTA Frameworks

Several research initiatives have addressed OTA security for constrained IoT devices. Jaouhari and Bouvet (2022) examined firmware update security challenges, proposing a trust chain architecture but leaving key establishment protocols and performance evaluation as future work. Asokan et al. (2018) developed ASSURED, implementing authorization tokens and device attestation, though their approach relies on static tokens lacking per update policy flexibility.

2.3 Zero Trust and Access Control

Zero Trust Architecture (ZTA) has emerged as a critical security paradigm for IoT systems, operating on the principle of 'never trust, always verify' [1]. Recent comprehensive surveys [2] have identified continuous authentication, policy enforcement points, and device verification as

essential components of Zero Trust implementations in IoT environments. James et al. [3] applied Zero Trust principles to IoT messaging through Attribute Based Access Control embedded within MQTT brokers, achieving continuous verification with minimal latency (<45ms). Colombo et al. examined access control enforcement challenges in IoT during the Zero Trust era, identifying the need for dynamic, context aware authorization mechanisms that can adapt to device state and operational context.

2.4 Lightweight Cryptography and Delta Updates

Vahdati et al. (2019) compared ECC and RSA [4] for IoT applications, demonstrating that ECC provides equivalent security with significantly smaller key sizes. Park et al. (2025) proposed lightweight firmware delivery using DEFLATE compression and dual key XOR encryption, achieving reduced latency and power consumption. Delta update mechanisms have shown substantial bandwidth reduction (up to 90%) by transmitting only binary differences between firmware versions [5].

2.5 Anomaly Detection and Device Attestation

Hristozov et al. (2018) developed runtime attestation for microcontrollers using DICE based schemes with Memory Protection Unit isolation [6]. Threshold based anomaly detection offers lightweight alternatives to ML intensive approaches, with researchers demonstrating effective detection of DoS attacks and device level anomalies using statistical thresholds suitable for constrained systems [7].

2.6 Fail Safe and Recovery Mechanisms

To guarantee the resilience of edge devices, Dual Bank (A/B) partitioning is considered an industry standard mechanism of obtaining atomic firmware updates. Such architecture keeps the system continuously online by maintaining functional backup of the last version of firmware which can immediately roll back on the occurrence of errors or power outage [8]. But this redundancy also adds considerable resource overhead, doubling flash storage needs, which in many cases is not feasible with the low cost resource constrained IoT microcontrollers [9]. More recent work (De Simon et al. (2025)) has been done on recoveries based on checkpoints and on delta compressed updates to minimize this overhead, but these strategies often add extra computational delays or compromise cryptographic verification assurances [10]. This has left the necessity of a recovery architecture that is efficient in storage, cryptographic integrity, and autonomous recovery of devices.

2.7 Industry Implementations

Commercial IoT platforms including AWS IoT Core, Azure IoT Hub, Eclipse Hawkbit, and Mender provide enterprise grade OTA management with device authentication and monitoring capabilities. These platforms excel in large scale orchestration but depend heavily on device hardware capabilities and may not suit low cost, severely constrained IoT devices.

2.8 Summary of Literature Findings

The literature review reveals that while significant progress has been made in individual security components such as encryption, authentication, attestation, and rollback protection, no existing solution provides an integrated framework combines zero trust authorization with continuous verification, lightweight secure delivery for bandwidth constrained environments, threshold based anomaly detection for pre update health assessment, fail safe recovery for resource limited devices, and comprehensive audit logging without excessive overhead.

This gap motivates the development of SecureTrustOTA as a holistic framework addressing security, efficiency, and reliability simultaneously while remaining practical for constrained IoT deployments.

2.2 Identification and significance of the problem

2.2.1 Research Problem Statement

Despite significant advances in IoT security and OTA update mechanisms, existing frameworks fail to address a critical vulnerability: the absence of integrated, real time trust verification and health assessment of IoT devices before firmware updates are deployed. Current solutions focus predominantly on securing the transmission channel and verifying update package integrity while if target devices exist in stable, trustworthy operational states [11].

The problem manifests in several critical scenarios,

- **Compromised Device Updates:** Malware infected devices receive legitimate firmware updates, but the compromised state prevents proper installation or allows malware to persist post update.
- **Resource Exhausted Devices:** Devices experiencing memory leaks, excessive CPU utilization, or critically low battery attempt updates, resulting in incomplete installations or permanent bricking.
- **Silent Failures:** Devices with degraded sensors or failing hardware successfully authenticate and download updates but fail during installation.
- **Attack Vector Amplification:** Attackers exploit the update mechanism by forcing devices into anomalous states before scheduled updates.

2.2.2 Novelty and Uniqueness

The SecureTrustOTA framework introduces several novel contributions distinguishing it from existing research:

1. Integrated Trust Based Update Gatekeeping

Unlike existing solutions treating device authentication and update delivery separately, SecureTrustOTA implements unified framework where real time device health assessment directly gates update authorization.

2. Four Layer Holistic Architecture

Uniquely integrates: (1) Zero Trust Authorization, (2) Lightweight Secure OTA Core, (3) Threshold Based Anomaly Detection, (4) Resilient Fail Safe Update Engine in resource efficient implementation.

3. Lightweight Threshold Based Anomaly Detection for OTA

Pioneers anomaly detection as mandatory pre update validation mechanism, avoiding ML overhead while providing deterministic, interpretable decisions.

4. Resource Optimized Security for Constrained Devices

Specifically targets microcontroller class devices with limited RAM (<512KB) and flash (<4MB), demonstrating achievable strong security without powerful processors.

5. Context Bound Challenge Response (CB-CCR) Authentication

Implements a novel 5 phase adaptive authentication system with 100 point trust scoring that combines ECC P-256 cryptographic identity, hardware fingerprinting based on the MCU UID, flash size, bootloader CRC, monotonic counters for replay attack prevention, and temporal continuity checks. Devices must achieve ≥ 70 trust score through verification of cryptographic signatures (40%), hardware context consistency (30%), and temporal continuity (30%). This approach implements Zero Trust principles as outlined in industry standards and extends adaptive authentication mechanisms for IoT contexts [12], incorporating hardware bound identity verification [13].

2.2.3 Scientific and Technical Challenge

The research addresses several significant technical challenges:

Challenge 1: Balancing Security Depth with Resource Constraints :

Implementing comprehensive security mechanisms on devices with 320KB RAM requires optimization of cryptographic libraries [14], strategic hardware acceleration use, memory efficient structures, and minimization of concurrent operations[15].

Challenge 2: Real Time Trust Assessment Without Performance Degradation :

Continuously monitoring telemetry, comparing against dynamic thresholds, and making authorization decisions in real time (<500ms) while maintaining device responsiveness. The adaptive trust scoring system must evaluate cryptographic proofs, hardware fingerprints, and temporal data within this latency constraint

Challenge 3: Fail Safe Recovery in Minimal Flash Memory :

Implementing A/B partitioning with golden recovery images on devices with 4MB flash requires delta update compression achieving >85% size reduction [16].

Challenge 4: Unified Framework Integration :

Orchestrating four complex subsystems into coherent framework requires careful API design, state management, error propagation, and maintainable architecture.

2.2.4 Significance and Impact

The significance of this research extends across multiple dimensions:

Academic Contribution: Advances IoT security knowledge by demonstrating comprehensive trust based OTA frameworks are feasible for severely constrained devices. Introduces novel CB-CCR authentication methodology combining hardware binding [17], monotonic counters, and adaptive trust scoring without requiring specialized security hardware.

Industrial Impact: Addresses critical pain points in large scale IoT deployments where failed updates cause operational disruptions and maintenance costs.

Security Enhancement: Reduces attack surface by preventing updates to compromised devices, detecting anomalous behavior before propagation, and ensuring continuous verification. The 5 phase authentication with hardware drift detection (5% threshold) and replay attack prevention through monotonic counters provides multi layered defense against sophisticated attacks, addressing critical IoT security vulnerabilities [18] and implementing comprehensive access control [19] aligned with Zero Trust Architecture principles.

Economic Benefit: Minimizes device replacement costs, reduces bandwidth costs through delta updates, lowers operational expenses through automated recovery.

3. Research Questions

The following research questions guide the investigation and establish measurable outcomes:

RQ1: Zero Trust Authorization Effectiveness

How can the 5 phase adaptive authentication system with ECC cryptography, hardware fingerprinting, monotonic counters, and adaptive trust scoring be efficiently implemented on resource constrained IoT devices to ensure continuous authentication without exceeding 20% CPU overhead or 50KB memory footprint?

Evaluation Metrics: CPU utilization, memory consumption, authentication latency (<500ms target), trust score calculation time, hardware drift detection accuracy, replay attack prevention success rate. These metrics align with Zero Trust Architecture evaluation criteria and lightweight authentication performance requirements for resource constrained IoT devices [20].

RQ2: Lightweight Secure Delivery Performance

What bandwidth reduction can be achieved through delta update mechanisms combined with ECC based signature verification and AES-CCM encryption compared to full firmware transfers?

Evaluation Metrics: Percentage bandwidth reduction, update transfer time, energy consumption, success rate under packet loss [21].

RQ3: Anomaly Detection Accuracy and Overhead

How effectively can threshold-based anomaly detection identify compromised or malfunctioning devices before update deployment, and what computational overhead does continuous telemetry monitoring introduce?

Evaluation Metrics: True positive rate, false positive rate, detection latency, CPU/memory overhead [22].

RQ4: Fail Safe Recovery Reliability

How reliably can the dual-slot update architecture with golden recovery image prevent permanent device bricking across various failure scenarios?

Evaluation Metrics: Rollback success rate, mean time to recovery, flash memory overhead, bootloader accuracy.

RQ5: Integrated Framework Scalability

How does the integrated SecureTrustOTA framework scale when managing simultaneous updates across heterogeneous IoT device fleets (100, 500, 1000 devices)?

Evaluation Metrics: Maximum concurrent update capacity, server resource utilization, network bandwidth consumption, average completion time.

RQ6: Security Posture Improvement

To what extent does the combined zero trust authorization, anomaly detection, and audit logging reduce the attack surface compared to traditional OTA systems?

Evaluation Metrics: Attack prevention success rate, audit log completeness, time to detect malicious attempts. Security posture evaluation will be conducted through comparative analysis against traditional OTA systems, measuring attack surface reduction consistent with Zero Trust principles and cyber physical systems security best practices

RQ7: Practical Deployment Feasibility

How feasible is deployment of SecureTrustOTA in real world IoT environments with varying network reliability, diverse device capabilities, and different operational contexts?

Evaluation Metrics: Deployment success rate, configuration complexity, operational stability, minimum viable specifications.

4. Research Objectives

4.1 Main Objective

To design, implement, and validate a comprehensive, resilient, and trust based Over the Air firmware update framework for resource constrained IoT devices that integrates zero trust authorization with 5 phase adaptive authentication, lightweight secure delivery mechanisms, real time anomaly detection, and fail safe recovery capabilities, thereby ensuring that only verified, authenticated, and health validated devices receive firmware updates while maintaining operational reliability, security, and efficiency suitable for large scale heterogeneous IoT deployments.

4.2 Specific Objectives

Component 1: Zero Trust Authorization Layer

Objective 1.1: Implement 5 Phase Adaptive Authentication with ECC P-256 -

Design and implement the complete authentication pipeline: (1) ECC P-256 key pair generation on device with hardware bound identity, (2) secure enrollment with hardware fingerprinting (MCU UID + flash size + bootloader CRC), (3) basic challenge response authentication, (4) context bound proofs with monotonic counters and temporal validation, (5) adaptive trust scoring (40% crypto + 30% hardware + 30% temporal). Target: authentication within 2 seconds on ESP32 with <30KB memory overhead. This multi phase approach extends score based authorization concepts for IoT systems, incorporating hardware fingerprinting techniques for device authentication and leveraging efficient elliptic curve cryptography suitable for resource constrained devices.

Objective 1.2: Develop Dynamic Policy Based Access Control with JWT Authorization -

Create flexible RBAC/PBAC enforcement using HS256 JWT tokens with device fingerprint binding and role based permissions (admin/technician/iot_device). Implement IP access management with priority based decision logic (blocklist → allowlist → default) and real time token revocation with SQLite persistence. This objective implements fine grained access control mechanisms addressing the challenges identified in Zero Trust IoT authentication surveys and enforces least privilege access principles essential for IoT security.

Objective 1.3: Integrate Firmware Attestation with SHA-256 and AES-256 Encryption –

Implement cryptographic firmware attestation using SHA-256 hashing with pre installation verification and AES 256 CBC encryption for end to end firmware protection with random IVs. Implement replay attack prevention through monotonic counters and timestamp validation (120s tolerance). Target: verification within 1 second for 1MB firmware. The firmware attestation

mechanism builds upon practical runtime attestation techniques for constrained IoT devices [8], ensuring cryptographic verification of firmware integrity before installation without requiring specialized hardware security modules.

Objective 1.4: Establish Comprehensive Audit Logging Across 9 Categories -

Design tamper evident logging with SQLite persistence capturing: device actions, authentication events, policy changes, system events, failures, hardware verification results, trust scores, challenge response exchanges, and context bound proofs. Implement hardware drift detection with 5% threshold and temporal continuity checks for clock skew detection. Hardware drift detection leverages device specific identifiers based on unique hardware characteristics [23] to identify potential tampering or device substitution attacks, while comprehensive logging supports the traceability requirements of Zero Trust architectures.

Component 2: Lightweight Secure OTA Core

Objective 2.1 : Efficient Incremental Updates –

The component implements incremental updates using binary delta patching with the bsdiff algorithm. This method allows firmware updates to transmit only the differences between versions, significantly reducing bandwidth usage and update time for ESP32 devices [24]. By using delta based updates instead of full firmware downloads, the system ensures efficient and timely updates suitable for resource constrained devices.

Objective 2.2 : Robust Cryptographic Security -

To maintain firmware authenticity and integrity, the component integrates ECC digital signatures. It also implements AES-256-CCM per device encryption, where each device has a unique key to prevent unauthorized access and replay attacks [25]. This combination of lightweight cryptography ensures strong security while remaining suitable for devices with limited resources.

Objective 2.3 : Secure and Efficient Communication -

The component supports HTTPS communication for secure server client interactions during OTA updates. In addition, streaming downloads are employed to manage memory usage efficiently, allowing firmware patches to be applied in real time without requiring large amounts of RAM. Together, these features ensure secure, reliable, and resource efficient updates.

Objective 2.4 : Real Time Monitoring and Diagnostics -

OLED displays provide live visual feedback during firmware updates, supporting two screens with split screen visualization to enhance user experience. The component also includes local server support, I2C bus scanning, and enhanced WiFi debugging, enabling effective network and hardware diagnostics during the update process.

Objective 2.5 : Integrated Secure OTA Framework -

This component forms a complete OTA solution by combining incremental updates, cryptographic security, secure communication, and real time monitoring into a single framework. By integrating these mechanisms, it eliminates the need for separate update and security systems, delivering a streamlined, robust, and user friendly OTA experience for ESP32 devices.

Component 3: Anomaly Detection Engine

Objective 3.1: Design Telemetry Collection Infrastructure -

Develop lightweight telemetry agents collecting CPU, memory, battery, storage, network metrics.

Objective 3.2: Implement Dynamic Threshold Management -

Create adaptive threshold systems using rolling window statistics and percentile based bounds to accommodate device heterogeneity [26].

Objective 3.3: Develop Real Time Anomaly Detection Logic -

Implement threshold comparison algorithms with debounce logic to prevent false positives and quorum rules for correlated anomaly detection.

Objective 3.4: Integrate Alert Generation and Dashboard -

Build monitoring dashboard displaying real time device status, anomaly alerts, historical trends, and actionable recommendations [27].

Component 4: Fail Safe Update Engine

Objective 4.1: Implement Dual Slot A/B Partitioning -

Implement Dual Bank A/B Partitioning with Atomic State Switching. Design a partitioning architecture safely using the non volatile storage (NVS) of the ESP32 to ensure that the ota0 (Active) and ota1 (Staging) firmware slots are strictly isolated. Introduce an Atomic State Machine to the bootloader which utilizes the otadata partition as a persistent flag, so that an exact one clock cycle partition switching will happen to avoid corruption in case of power outage.

Target: Pswitch latency Partition Within zero risk of bricking on localized power failures less than 500ms. The strategy is based on the hardware native redundancy of the current microcontrollers to ensure the availability of systems [28].

Objective 4.2: Develop Rollback Protection Mechanisms -

Implement Cryptographic Rollback Protection & Integrity Checking. Implement a pre boot validation pipeline that makes use of SHA 256 Cryptographic Hashing to check the integrity of firmware before running. Implement a Version Aware rollback mechanism enabling monotonic counters to ensure that the roll back mechanism does not admit any Downgrade Attacks (attempting to install vulnerable old firmware) but does admit legitimate emergency rollbacks. In case the SHA-256 hash is not the same as the signed manifest, the system will automatically restore the system to the "Last Known Good" configuration.

Target: 1MB firmware payload should be verified within less than 2 seconds. This scheme deals with Integrity Availability Trade off that is frequently mentioned in edge computing literature [29].

Objective 4.3: Create Automatic Recovery Logic -

Make Multi stage Recovery Worker Design a multi stage recovery system by making use of the Hardware Watchdog Timer (TG0WDT) to monitor non responsive states, boot loops, or kernel panics. Apply a logic of the Boot Counter, which counts the number of failed starting tries; in case the failure limit ($n=3$) is reached, the system automatically falls back to the Golden Image.

Target: Mean Time To Recovery (MTTR) (without human intervention) less than 60 seconds. Such autonomy of self healing is vital when implementing the IoT devices in hostile or unreachable settings.

Objective 4.4: Optimize Update Scheduling -

Create Forensic Black Box Failure Analysis Have a robust logging sub system that records critical failure logs (Core Dumps, Stack Trace and Reboot Reason) on SD card partition just before a system crash. This "Black Box" persistence, in contrast to the standard volatile logs, allows forensic data to survive the reboot process so that root cause analysis of field failures is possible.

Target: Write less than 15ms to record unsteady information prior to complete power loss. This completes the lack of granular, device side forensic evidence that is present in the traditional IoT monitoring [30].

Integration and Validation (All Team Members)

Objective 5.1: Achieve Seamless Component Integration

Integrate all four components into cohesive framework with well defined APIs, state management, error handling, and workflow orchestration.

Objective 5.2: Conduct Comprehensive System Validation

Perform systematic testing covering functional correctness, security effectiveness, performance benchmarking, scalability assessment, and reliability validation.

Objective 5.3: Evaluate Real World Deployment Feasibility

Assess practical deployment viability across different IoT platforms, network conditions, and operational contexts.

Objective 5.4: Document Framework Architecture

Produce comprehensive technical documentation, including system architecture, API references, deployment guides, and security considerations.

5. Research Methodology

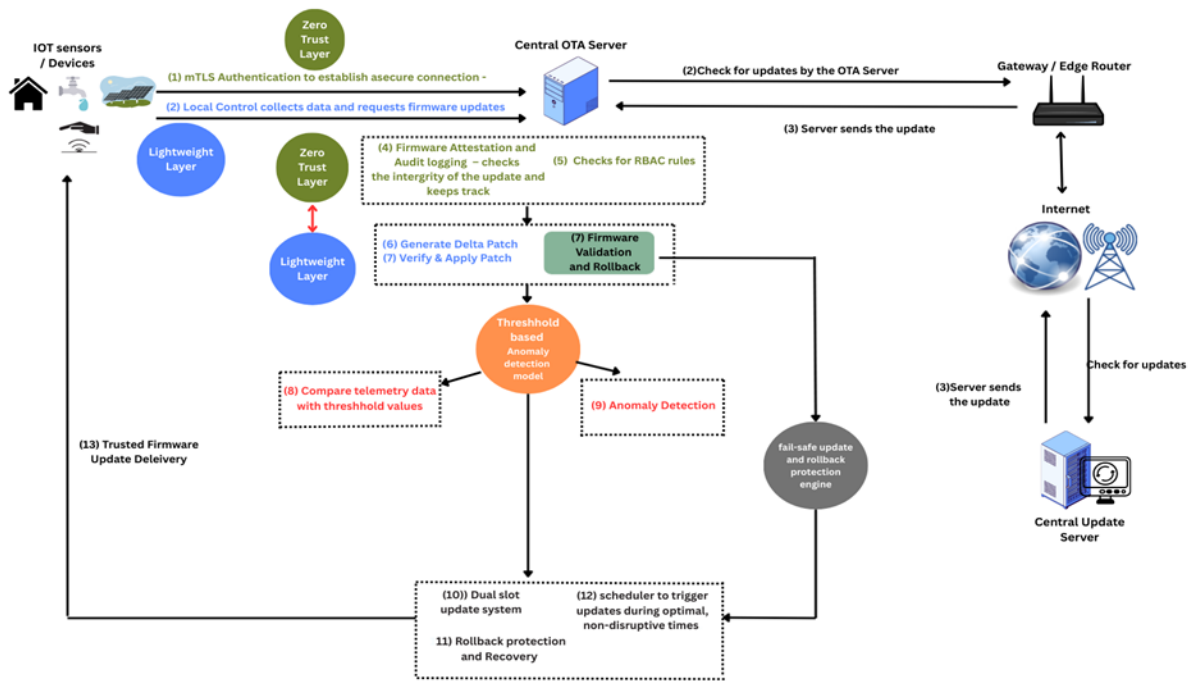


Figure 1: System diagram

The overall system works with the corporation of 4 layers indicated in 4 colors.

Color	Layer Number	Indicated Layer
Green	Layer # 1	Zero Trust Authorization and policy enforcement Layer
Blue	Layer #2	Lightweight Secure OTA Core
Orange	Layer #3	Threshold Based Anomaly Detection Engine
Grey	Layer #4	Resilient Fail Safe Update Engine

Table 2. Color indicators for each component

- Layer 1: Zero Trust Authorization Layer

The system begins by enabling strict identity verification through mutual TLS (mTLS), where both the device and the update server authenticate each other to ensure only trusted parties can communicate. Once the connection is established, role based and policy based permissions control what actions each device is authorized to perform and by whom to receive the updates, such as requesting or applying updates. Before any installation takes place, firmware attestation mechanisms verify the legitimacy and integrity of the update package and the device, ensuring it has not been tampered with or replaced by malicious code. Finally, all activities are continuously logged and audited, providing a complete trace of the update process for accountability, compliance, and forensic analysis.

The flow: Authenticate → Authorize → Verify → Log & Audit

- Layer 2: Lightweight Secure OTA Core

The process begins with the Local Control unit, which is responsible for gathering device data and initiating firmware update requests. Once an update is available, the Delta Patch Generator computes the difference between the existing firmware and the new version, producing a lightweight patch. This patch is then encrypted using ECC and AES CCM to ensure both confidentiality and integrity during transmission. Before installation, the Verify & Apply Patch stage validates the authenticity of the update, making sure it has not been altered or injected with malicious code. Following this, Firmware Validation and Rollback mechanisms safeguard the device by running health checks on the new firmware; if any failures or instabilities are detected, the system automatically reverts to the last stable version. Finally, the Alert Dashboard provides visibility to administrators by connecting back to the central server and displaying anomalies or unusual activities detected throughout the update process.

The flow: Collect → Generate & Encrypt → Verify & Apply → Validate / Rollback → Alert & Monitor.

- Layer 3: Threshold Based Anomaly Detection Engine

IoT devices continuously send telemetry data to the central OTA server through log forwarding agents, allowing the system to track their operational status. The received data is compared against predefined threshold values stored in the database to determine whether the device is functioning within acceptable limits. If the readings fall within these thresholds, the update process proceeds as expected. However, if any anomalies are detected such as abnormal battery levels, excessive CPU usage, or updates requested outside the permitted time window an alert is automatically generated and displayed on the monitoring dashboard. This ensures that only healthy and stable devices receive updates, while potential risks are flagged for further investigation.

The flow: Telemetry → Compare with thresholds → If normal, update → If abnormal, alert & monitor.

- Layer 4: Resilient Fail Safe Update Engine

To ensure that the system can survive the Over the Air (OTA) transmission, the methodology uses **Resilient Fail Safe Update Engine** which is built on a Dual Bank (A/B) flash architecture. This layer operates as a **deterministic state machine** that is meant to prevent the corruption of firmware and to guarantee that updates are atomic. The procedure would run through four phases:

1. Pre Installation Cryptographic Checking: When the download occurs the firmware binary is subjected to integrity verification pipeline. The checksum (SHA-256) of the signed manifest is computed and compared to validate the authenticity and integrity of the payload prior to the completion of any write operation against the payload.
2. Isolated Staging Strategy: Tested firmware is stored to the second passive partition (ota1 or ota0), which is the Staging Area. This makes sure that the active runtime environment is not disturbed in the course of writing as it does not interrupt system availability.
3. Conditional Boot Switching: Bootloader changes the otadata partition flags in Non Volatile Storage (NVS) to conditionally switch active boot slot. This is an atomic operation and in the event of the power failure during the switch, the system will automatically revert to the former condition safely.
4. Stability Monitoring: A hardware Watchdog Timer (WDT) starts a "Check up Period" after the booting. In case the new firmware does not restart the watchdog (signifying a crash, hang, or loop), within the stipulated time (60s), then a system **Automatic Rollback** occurs, restoring the boot flag to the previous known stable firmware.

The flow: Payload → Verify → Stage → Switch → Validate → Commit/Rollback.

6. Anticipated Benefits

6.1 Benefits to Users

- **Enhanced Security:** Comprehensive protection against unauthorized updates, compromised devices, and firmware tampering.
- **Improved Reliability:** Fail safe mechanisms preventing device bricking, automatic recovery from failed updates.
- **Reduced Downtime:** Efficient delta updates minimizing update duration, intelligent scheduling reducing operational disruption.
- **Cost Savings:** Reduced bandwidth consumption (>85% savings), minimized manual intervention requirements, lower device replacement costs.
- **Operational Visibility:** Comprehensive audit logs, real time monitoring dashboard, anomaly detection alerts.

6.2 Contribution to Body of Knowledge

- **Novel Integration Framework:** First comprehensive framework combining zero trust authorization, lightweight secure delivery, anomaly detection, and fail safe recovery specifically for constrained IoT devices.
- **Threshold Based Anomaly Detection Methodology:** Replicable pattern for pre update device health assessment without ML overhead, applicable to other resource limited security contexts.
- **Resource Optimized Security Techniques:** Demonstrates achievability of comprehensive security on severely constrained hardware, challenging assumptions about security resource trade offs.
- **Practical Deployment Guidelines:** Documented best practices for large scale IoT OTA deployments, configuration strategies, troubleshooting procedures.
- **Standardization Potential:** Modular architecture and well defined interfaces positioning framework as candidate for IoT security standards from IETF, NIST, ISO/IEC.

7. Scope and deliverables

7.1 Scope

This research will:

- Design and implement complete SecureTrustOTA framework integrating all four components.
- Target ESP32 microcontroller platforms as primary test devices.
- Support Wi Fi and cellular connectivity for firmware delivery.
- Implement cryptographic protocols (mTLS, ECC, AES-CCM) optimized for constrained devices.
- Develop server side backend (Python) and device firmware (C++).
- Create React based monitoring dashboard for administrators.
- Conduct comprehensive testing covering security, performance, scalability, and reliability.

This research will NOT:

- Develop hardware specific security modules (TPM, secure elements) will use software based cryptography.
- Support real time operating systems beyond FreeRTOS - focus on bare metal and FreeRTOS implementations.
- Implement blockchain based update verification - will use traditional PKI.
- Provide commercial grade production deployment - academic prototype demonstrating feasibility.

7.2 Specified Deliverables

1. Functional SecureTrustOTA prototype system with all four integrated components.
2. Source code repository with comprehensive documentation.
3. Technical documentation including system architecture, API specifications, deployment guides.
4. Experimental evaluation report with performance metrics, security analysis, scalability results.
5. Research publications (conference/journal papers) based on findings.
6. Project demonstration video showcasing system capabilities.
7. Final dissertation document meeting academic requirements.

8. Research Constraints

- **Hardware Constraints:**
Limited to devices with minimum 320KB RAM and 4MB flash; specialized security hardware (TPM) not available; testing constrained to purchased development boards (4-6 units).
- **Time Constraints:**
8 month project timeline limiting scope of testing and optimization; academic calendar requiring milestone completion by specified deadlines.
- **Budget Constraints:**
Total budget approximately LKR 46,500 limiting scale of testing infrastructure; reliance on free tier cloud services and open source tools.
- **Network Constraints:**
Testing limited to simulated network conditions; cannot deploy in actual industrial environments; dependent on lab network infrastructure.
- **Technical Constraints:**
Cryptographic operations limited by device hardware capabilities; delta update compression ratios dependent on firmware similarity; anomaly detection accuracy limited by threshold calibration.
- **Scope Constraints:**
The scope is limited of firmware updates only and does not include configuration management. The work presents a prototype implementation rather than a production ready system. The solution is limited to specific device platforms such as ESP32.

9. Project plan and Schedule

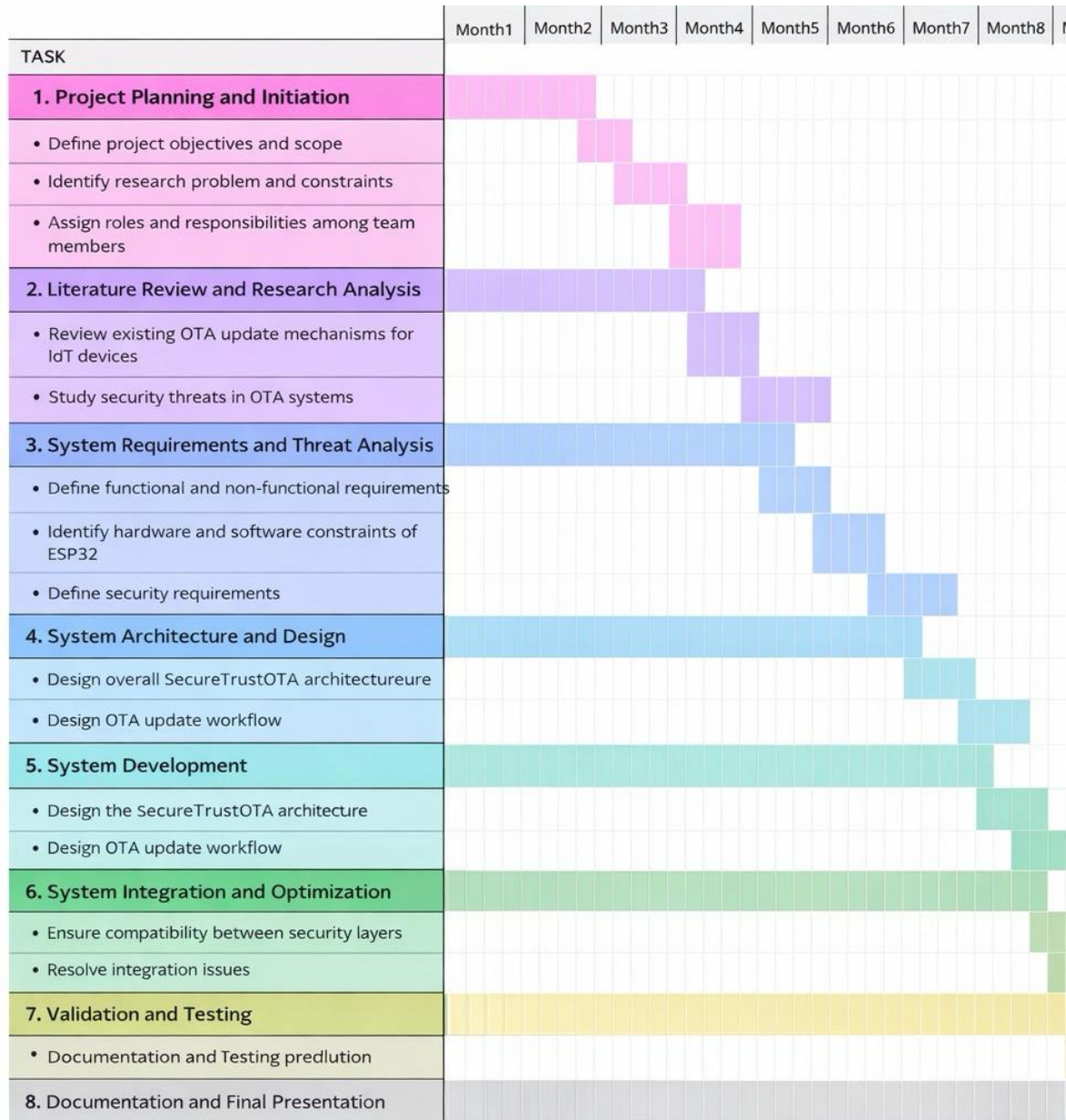


Figure 2: Project Plan

10. Budget and Justification

Item	Quantity	Unit Cost (LKR)	Total Cost (LKR)
Laptop/PC (Already existing)	-	0	0
IoT Development Boards (ESP32)	4	6,500	26,000
Storage Devices (USB drives / SD cards)	4	1,000	4,000
Networking Devices (Wi-Fi Router / Switch)	1	8,500	8,500
Software Tools & Libraries	-	0	0
Cloud Resources (Testing - Free Tier)	-	0	0
Printing & Documentation	-	-	3,000
Cables, Connectors, Power supplies	-	-	5,000
TOTAL			46,500

Table 3. Budget summary

11.1 Budget Justification

Development Boards: ESP32 boards provide sufficient processing power for IoT simulation and OTA testing. Each team member requires independent development board.

Networking Equipment: Shared Wi-Fi router creates realistic testbed for OTA experiments under typical IoT networking conditions.

Software Resources: Open source development platforms and cryptographic libraries (Arduino IDE, PlatformIO, OpenSSL, Wireshark) available without cost.

Cloud Infrastructure: Free tier services and student plans from AWS IoT Core / Azure IoT Hub support simulation without subscription costs.

Miscellaneous: Allocation for printing project proposal, final report, and essential project materials.

11. References

- [1] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, "Zero Trust Architecture," NIST Special Publication 800-207, National Institute of Standards and Technology, Aug. 2020.
- [2] C. Liu, Y. Feng, D. Lin, L. Wu, and M. Guo, "Dissecting Zero Trust: Research Landscape and Its Implementation in IoT," *Cybersecurity*, vol. 7, no. 1, p. 20, May 2024.
- [3] M. James, A. Sajid, and R. Mehmood, "Authentication and Authorization in Zero Trust IoT: A Survey," in *Proc. 35th Irish Signals and Systems Conf. (ISSC)*, Belfast, UK, June 2024, pp. 1–6.
- [4] Z. Vahdati, S. M. Yasin, A. Ghasempour, and M. Salehi, "Comparison of ECC and RSA algorithms in IoT devices," *Journal of Theoretical and Applied Information Technology*, vol. 97, no. 16, 2019. [Online]. Available: <https://www.jatit.org/volumes/Vol97No16/6Vol97No16.pdf>
- [5] J. Park *et al.*, "Secure and lightweight firmware over-the-air update mechanism for IoT," *Electronics*, vol. 14, no. 8, p. 1583, 2025.
- [6] [1] S. Hristozov, J. Heyszl, S. Wagner, and G. Sigl, "Practical runtime attestation for tiny IoT devices," in *NDSS Workshop on Decentralized IoT Security and Standards (DISS)*, 2018. [Online]. Available: https://www.ndss-symposium.org/wp-content/uploads/2018/07/diss2018_11_Hristozov_paper.pdf
- [7] "Method of detecting anomalies in IoT device traffic based on locality-aware signature detection (LSAD)," *CEUR Workshop Proceedings*, 2023.
- [8] K. Zandberg, K. Schleiser, F. J. Acosta Padilla, H. Tschofenig, and E. Baccelli, "Secure Firmware Updates for Constrained IoT Devices Using Open Standards: A Reality Check," *IEEE Access*, vol. 7, pp. 12345–12358, 2019.
- [9] F. Mahfoudhi, A. K. Sultania, and J. Famaey, "Over-the-Air Firmware Updates for Constrained NB-IoT Devices," *Sensors*, vol. 22, no. 19, p. 7572, 2022. [10] A. De Simone, G. Turvani, and F. Riente, "Incremental Firmware Update Over-the-Air for Low-Power IoT Devices over LoRaWAN," *arXiv*, May 19, 2025.
- [11] N. F. Syed, S. W. Shah, A. Shaghaghi, A. Anwar, Z. Baig, and R. Doss, "Zero Trust Architecture (ZTA): A Comprehensive Survey," *IEEE Access*, vol. 10, pp. 57143–57179, 2022.

- [12] S. Ameer, J. Benson, and R. Sandhu, "BlueSky: Towards Convergence of Zero Trust Principles and Score-Based Authorization for IoT Enabled Smart Systems," *IEEE Trans. Dependable Secure Comput.*, 2022, Early Access.
- [13] Y. Xiao, Y. He, X. Zhang, Q. Wang, R. Xie, K. Sun, K. Xu, and Q. Li, "From Hardware Fingerprint to Access Token: Enhancing the Authentication on IoT Devices," in *Proc. Network and Distributed Security Symp. (NDSS)*, San Diego, CA, USA, Feb. 2024.
- [14] S. Kumari, M. Karuppiyah, A. K. Das, X. Li, F. Wu, and N. Kumar, "A Secure Authentication Scheme Based on Elliptic Curve Cryptography for IoT and Cloud Servers," *J. Supercomput.*, vol. 74, no. 12, pp. 6428–6453, May 2018.
- [15] L. Zhang, Y. Wang, J. Liu, and X. Chen, "A Lightweight Zero-Trust Authentication Architecture for IoT via Unified Enhanced FAST-SM9 and Dynamic Re-Authentication," *PLOS ONE*, vol. 19, no. 10, p. e0332943, Oct. 2024.
- [16] "A/B (seamless) system updates," Android Open Source Project, 2025. [Online]. Available: <https://source.android.com/docs/core/ota/ab>
- [17] [8] S. Hristozov, J. Heyszl, S. Wagner, and G. Sigl, "Practical Runtime Attestation for Tiny IoT Devices," in *Proc. NDSS Workshop on Decentralized IoT Security and Standards (DISS)*, San Diego, CA, USA, Feb. 2018.
- [18] P. Colombo, E. Ferrari, and E. D. Tümer, "Access Control Enforcement in IoT: State of the Art and Open Challenges in the Zero Trust Era," *ACM Comput. Surv.*, vol. 55, no. 3, pp. 1–38, Feb. 2023.
- [19] K. Humayed, J. Lin, F. Li, and B. Luo, "Cyber-Physical Systems Security—A Survey," *IEEE Internet Things J.*, vol. 4, no. 6, pp. 1802–1831, Dec. 2017.
- [20] "Zero trust architecture," Wikipedia, The Free Encyclopedia, 2025. [Online]. Available: https://en.wikipedia.org/wiki/Zero_trust_architecture
- [21] J. R. Sorensen, S. A. Rashid, H. ElHussini, and A.-M. Dan, "Evaluating Differential Firmware Updates for Embedded IoT Device Fleets," in **Proc. 2025 IEEE Workshop on Firmware Updates and IoT Systems**, 2025, pp. 1–8. [Online]. Available: <https://andreidan.net/assets/wfcs25.pdf>

[22] B. S. A. Ayan Chatterjee, "IoT anomaly detection methods and applications: A survey," Science Direct.

[23] M. S. Asplund, V. K. Nadjm-Tehrani, and J. Hall, "IoT-ID: A Novel Device-Specific Identifier Based on Unique Hardware Fingerprints," in *Proc. IEEE/ACM Third Int. Conf. Internet-of-Things Design and Implementation (IoTDI)*, Berlin, Germany, Apr. 2018, pp. 209–218.

[24] B. Wald, "Reducing the Cost of Fleet Software Management with Delta Updates," 27 August 2025. [Online]. Available: <https://www.verytechnology.com/insights/reducing-the-cost-of-fleet-software-management-with-delta-updates>. [Accessed 27 August 2025].

[25] M. Dworkin, "Recommendation for Block Cipher Modes of Operation: The CCM Mode for Authentication and Confidentiality," National Institute of Standards and Technology (NIST), Gaithersburg, MD, 2007.

[26] D. G. H. e. al, "Machine Learning Algorithms for Anomaly Detection in IoT," *Migration Letters*.

[27] B. S. A. Ayan Chatterjee, "IoT anomaly detection methods and applications: A survey," Science Direct.

[28] K. Zandberg, K. Schleiser, F. J. Acosta Padilla, H. Tschofenig, and E. Baccelli, "Secure Firmware Updates for Constrained IoT Devices Using Open Standards: A Reality Check," *IEEE Access*, vol. 7, 2019.

[29] F. Mahfoudhi, A. K. Sultania, and J. Famaey, "Over-the-Air Firmware Updates for Constrained IoT Devices," *Sensors*, vol. 22, no. 19, 2022.

[30] S. El Jaouhari and E. Bouvet, "Secure Firmware Over-the-Air Updates for IoT: Survey, Challenges, and Discussion," *Journal of Network and Computer Applications*, Elsevier, 2024.

12. Appendices

Table 1. List of Abbreviations

Table 2. Color indicators for each component

Table 3. Budget summary

Figure 1: System diagram

Figure 2: Project Plan